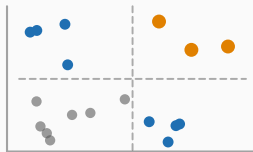


Risque opérationnel et résilience

Chapitre 13 : La gestion du risque tiers



Avant de commencer

Définir le risque tiers

Le cycle du risque tiers

Étude de cas : Capital One

Étude de cas : Morgan Stanley

Synthèse

Avant de commencer

Pourquoi ce chapitre ?

Le chapitre précédent a posé les principes de la gestion du risque prestataire. Ce chapitre les prolonge sous l'angle plus large de la gestion du risque tiers (Third-Party Risk Management, TPRM), à travers deux études de cas retentissantes — Capital One et Morgan Stanley — qui montrent ce qu'il en coûte lorsque ces principes ne sont pas appliqués avec rigueur.

Définir le risque tiers

Un périmètre qui s'étend au-delà du prestataire direct

Tiers, quatrième partie, cinquième partie

La gestion du risque tiers désigne l'ensemble du processus par lequel un établissement identifie, évalue et maîtrise les risques associés à ses relations avec des prestataires externes. Ce périmètre ne s'arrête pas au prestataire direct (le « tiers ») : il s'étend aux sous-traitants de ce prestataire (« quatrième partie ») et, potentiellement, aux sous-traitants de ces derniers (« cinquième partie »). Un établissement reste exposé aux défaillances survenant à chacun de ces niveaux, même lorsqu'il n'a aucune relation contractuelle directe avec eux.

Une catégorie taxonomique en devenir

Dans la taxonomie de Bâle sur les pertes de risque opérationnel, le risque tiers apparaît comme une sous-catégorie de niveau 2 au sein de la gestion de l'externalisation — mais de nombreux établissements, ainsi que la taxonomie révisée de l'ORX, le traitent désormais comme une catégorie de niveau 1 à part entière, reflet de son importance croissante et de sa spécificité.

Le cycle du risque tiers

Cinq étapes, selon le cadre du Shared Assessments Program

Les cinq étapes du cycle de vie

Le cadre proposé par le Shared Assessments Program décrit cinq étapes. **La décision de modèle d'affaires** : déterminer si le recours à un tiers est justifié et quel type de relation est recherché.

L'évaluation, la notation du risque et la diligence raisonnable : qualifier le tiers pressenti et son niveau de risque avant tout engagement. **Les contrats et accords de niveau de service (SLA)** : formaliser les obligations réciproques et les normes de performance attendues. **Le suivi continu** : surveiller la relation dans la durée, en fonction du niveau de risque attribué. **La remédiation ou la résiliation** : agir lorsque la relation se dégrade, jusqu'à y mettre fin si nécessaire.

Un cycle, pas une liste de contrôle ponctuelle

La présentation en cycle de vie souligne que la gestion du risque tiers ne s'arrête jamais à la signature du contrat : la phase de suivi continu et la possibilité de remédiation ou de résiliation font partie intégrante du dispositif, au même titre que la sélection initiale.

Étude de cas : Capital One

Une brèche touchant environ 100 millions de personnes

Les faits

En juillet 2019, Capital One a révélé une violation de données ayant exposé les informations personnelles d'environ 100 millions de personnes aux États-Unis. L'attaquante, une ancienne employée d'Amazon Web Services (AWS), a exploité une mauvaise configuration d'un pare-feu applicatif web (WAF) hébergé sur l'infrastructure cloud de Capital One pour mener une attaque de type Server-Side Request Forgery (SSRF), lui permettant d'accéder à des données stockées sur AWS. Elle a été arrêtée peu après les faits.

La sanction de l'OCC : 80 millions USD

L'Office of the Comptroller of the Currency (OCC) a infligé une amende de 80 millions USD à Capital One, motivée non par l'attaque elle-même mais par l'insuffisance des processus d'évaluation des risques mis en œuvre **avant** la migration vers l'infrastructure cloud publique. Le régulateur a jugé que la banque n'avait pas correctement évalué les risques inhérents à ce type d'architecture ni mis en place les contrôles compensatoires appropriés.

La responsabilité ne se délègue pas à l'infrastructure du tiers

Le cas Capital One illustre un principe central du risque tiers : recourir à un prestataire technologique de premier plan comme AWS ne dispense pas l'établissement d'évaluer et de maîtriser lui-même les risques de configuration et d'architecture de son propre environnement hébergé. La compétence du tiers ne remplace pas la diligence raisonnable de son client.

Étude de cas : Morgan Stanley

Deux incidents de décommissionnement, cinq ans d'écart

Les faits

Morgan Stanley a été sanctionnée par l'OCC à hauteur de 60 millions USD pour des défaillances dans la gestion et la surveillance des risques liés à ses tiers, à l'occasion du décommissionnement de serveurs de gestion de patrimoine en 2016 puis à nouveau en 2019. Dans les deux cas, les processus de retrait des équipements n'ont pas garanti l'effacement sécurisé ou la destruction appropriée des données clients qui y étaient stockées.

Une répétition qui aggrave la faute

Ce qui distingue le cas Morgan Stanley, c'est la récurrence : un premier incident en 2016 aurait dû déclencher une révision en profondeur des procédures de décommissionnement; sa répétition en 2019 a été interprétée par le régulateur comme la preuve que les enseignements du premier incident n'avaient pas été tirés — un manquement à la surveillance continue, pas seulement à un contrôle ponctuel.

Le décommissionnement, un angle mort classique du risque tiers

La fin de vie d'un actif ou d'une relation tierce — retrait de matériel, résiliation de contrat, migration vers un nouveau prestataire — est souvent moins scrutée que sa mise en place. Les deux études de cas Capital One et Morgan Stanley montrent que les moments de transition (migration vers le cloud, décommissionnement de serveurs) concentrent un risque disproportionné par rapport à l'attention qui leur est généralement accordée.

Synthèse

Synthèse du chapitre

La gestion du risque tiers étend la logique du chapitre précédent à l'ensemble de la chaîne de sous-traitance — tiers, quatrième et cinquième parties — et s'organise en un cycle de vie continu : décision de modèle d'affaires, évaluation et diligence raisonnable, contractualisation, suivi continu, remédiation ou résiliation. Les cas **Capital One** (80 millions USD, insuffisance d'évaluation des risques avant migration cloud) et **Morgan Stanley** (60 millions USD, défaillances répétées de décommissionnement) montrent que les sanctions les plus lourdes sanctionnent moins l'incident lui-même que l'absence de dispositif de contrôle robuste en amont — et que les moments de transition technologique restent le point faible le plus fréquent.